Security Vulnerability Assessment and IT Risk Analysis: UPSA Information Systems

Student: TWUMASI ANKRAH DERRICK · **Index Number:** 10353431 · **Course:** BSIT309

1. Executive Summary

This report assesses two core information systems at the University of Professional Studies, Accra (UPSA): **(1) the Student Information System (SIS) and its online portals** (course registration, fee payment, admissions, grades) and **(2) the campus network and Wi-Fi infrastructure** that connects students, staff and servers.

The assessment found **16 realistic vulnerabilities**: 2 rated Critical, 12 High and 2 Medium. The most serious are weak authentication on the student portal, a flat network with weak segmentation between student and administrative zones, and limited audit logging and monitoring. Section 6 gives detailed technical controls for each, and Section 7 gives a prioritised 180-day roadmap.

Important scope note. This is a *desk-based* assessment built from public information and from weaknesses that are well documented in university environments. No scanning, probing or testing of any live UPSA system was performed, because that requires written authorisation from the university. Findings are therefore stated as *likely* or *potential* and should be confirmed through an authorised test. This caution is real: in February 2017 UPSA dismissed 22 students for tampering with its student information system to alter grades.

2. Scope, Methodology and Rating Scale

Methodology. Risk assessment follows **NIST SP 800-30** (identify assets, threats, vulnerabilities, likelihood, impact, then risk). Web findings are mapped to the **OWASP Top 10**, and controls are aligned with **ISO/IEC 27001 Annex A**, the **NIST Cybersecurity Framework**, and Ghana's **Data Protection Act, 2012 (Act 843)** and **Cybersecurity Act, 2020 (Act 1038)**.

Information sources. Public UPSA student guides and portals, news reports on UPSA, and the government free Wi-Fi project for tertiary institutions (UPSA is one of 13 named beneficiaries, connected through ECG fibre).

Risk rating. Risk score = Likelihood (1–5) × Impact (1–5).

Score	Rating
1–5	Low
6–11	Medium
12–19	High

20–25 Critical

3. System 1: Student Information System and Online Portals

3.1 Description and assets

Public student guides describe a layered set of web systems: an online student portal for course registration, a separate third-party payment platform (Interpay Africa) where students record bank fee payments, an online admissions application, and the main university website. Note that one guide dates from 2017, so URLs and workflows should be confirmed with UPSA.

Key assets: student academic records and grades, personal data (names, contact details, identity documents submitted at admission), fee and payment records, admission applications, staff and administrator credentials. **3.2 Trust boundaries and exposures**

Boundary / exposure	Why it matters
Internet to portal login page	Internet-facing, reachable by anyone; target for credential stuffing and injection
Portal hosted on a domain outside upsa.edu.gh	Students cannot easily tell the real portal from a look-alike; third-party domain ownership becomes a dependency
University to third-party payment platform	Payment data and student identity cross an organisational boundary; manual recording of bank payments invites fraud and reconciliation errors
Student to staff privilege boundary	Grade and registration changes must be restricted to authorised staff; the 2017 incident shows this boundary has failed before
Application to database	Any input flaw can expose the whole student dataset
Backups and exports (spreadsheets, e-mail)	Data leaves the controlled system and is often unencrypted

3.3 Vulnerabilities identified

ID	Vulnerability	Likelihood	Impact	Score	Rating
S-1	Weak or predictable credentials; no multi-factor authentication; no lockout (OWASP A07)	4	5	20	**Critical**
S-2	Broken access control, including insider and student grade tampering (OWASP A01)	3	5	15	High

3	S- Injection and weak input validation in legacy web forms (OWASP A03)	3	5	15	High
4	S- Manual payment reconciliation and portals on non-institutional domains	4	4	16	High
5	S- Insufficient audit logging and segregation of duties (OWASP A09)	4	4	16	High
6	S- Weak transport and storage protection (TLS misconfiguration, plaintext personal data, unencrypted backups) (OWASP A02)	3	4	12	High
7	S- Phishing and look-alike portal attacks against students	4	3	12	High
8	S- Unpatched or end-of-life components (OWASP A06)	3	4	12	High

Vulnerability details

- **S-1.** Student systems commonly use the index number as the username and a default or guessable first password (for example a date of birth). With no MFA, no rate limiting and no lockout, credential stuffing and brute force are practical. A single compromised student account exposes personal and financial data.
- **S-2.** If the server trusts record identifiers sent by the browser, a student can change an identifier to read or alter another student's data (an insecure direct object reference). Privileged staff accounts that can change grades without a second approver create insider risk. The 2017 grade-tampering incident is a documented precedent.
- **S-3.** Older PHP or ASP forms that build SQL queries by string concatenation allow SQL injection, which can read, change or delete grades and personal data.

- **S-4.** Students record payments made at a bank by entering them into a separate platform. Without automated, signed confirmation from the bank, forged receipts, duplicate entries and mismatched records are likely. Portals on domains other than the university's own make phishing easier and create dependency on third-party domain ownership.
- **S-5.** Without tamper-evident logs of who changed what and when, fraud is hard to detect and impossible to prove. One administrator able to both enter and approve grade changes removes the main safeguard.
- **S-6.** Outdated TLS versions, missing HSTS, personal data stored in plaintext columns, and unencrypted database dumps or e-mailed spreadsheets expose data at rest and in transit.
- **S-7.** Students are a large, trusting audience. Fake fee-payment or results pages are easy to build and spread through social media.
- **S-8.** Legacy CMS, PHP versions and libraries that no longer receive security fixes carry known exploitable flaws.

4. System 2: Campus Network and Wi-Fi Infrastructure

4.1 Description and assets

UPSA is one of 13 institutions in the government's free Wi-Fi for tertiary institutions project, which is anchored on ECG's fibre network and adds large numbers of access points across campuses. A campus network of this kind carries student devices, staff workstations, administrative servers, the SIS and internet-facing services.

Key assets: core and distribution switches, firewalls and routers, wireless controllers and access points, DNS and DHCP servers, authentication servers, server room, wiring closets, and the traffic that flows through them.

4.2 Trust boundaries and exposures

Boundary / exposure	Why it matters
Internet edge (ISP and government fibre link)	Entry point for DDoS, scanning and malware command traffic
Student/guest Wi-Fi to administrative LAN	Thousands of unmanaged personal devices share airspace with sensitive systems
Wireless air interface	Anyone within range can capture traffic or broadcast a fake access point

Management plane (switch, controller and AP admin interfaces)	Full control of the network if reached with default or stolen credentials
Server room and wiring closets	Physical access bypasses most logical controls
Shared services (DNS, DHCP)	Attacks here redirect or disrupt every user

4.3 Vulnerabilities identified

ID	Vulnerability	Likelihood	Impact	Score	Rating
N-1	Flat network and weak segmentation between student, staff and server zones	4	5	20	**Critical**
N-2	Wi-Fi weaknesses: shared or open networks, evil twin and rogue access points, captive-portal credential capture	4	4	16	High
N-3	Layer 2 attacks: ARP spoofing, rogue DHCP, MAC flooding	4	3	12	High
N-4	Default credentials and exposed management interfaces (Telnet, HTTP, SNMP v1/v2c)	3	5	15	High
N-5	Unmanaged and BYOD devices, malware spreading across the network	5	3	15	High
N-6	Denial of service and bandwidth abuse	4	3	12	High
N-7	Limited monitoring, intrusion detection and log retention	4	4	16	High
N-8	Physical security and power resilience of network rooms	2	4	8	Medium

Vulnerability details

N-1. If student Wi-Fi can reach administrative workstations and servers directly, one infected laptop or malicious user can scan and attack internal systems, including the SIS database.

- **N-2.** A single pre-shared key known to thousands of users lets any holder decrypt others' traffic. Open networks with a web login page expose credentials. Attackers can broadcast an access point with the same name to capture logins.

-

- **N-3.** Without switch protections, a user can poison ARP caches to intercept traffic (man-in-the-middle), run a rogue DHCP server to hand out a malicious gateway or DNS server, or flood switch tables.
- **N-4.** Network equipment left on factory passwords, or reachable over unencrypted protocols from user networks, can be taken over, giving an attacker control of all traffic.
- **N-5.** Without device checks, infected or outdated devices join freely, and worms, cryptominers and botnet clients spread.
- **N-6.** Without per-user rate limiting or upstream DDoS protection, heavy downloads or attack traffic degrade service for the whole campus and for the online systems that depend on it.
- **N-7.** If logs are not collected centrally and nobody reviews alerts, intrusions go unnoticed for weeks.
- **N-8.** Unlocked wiring closets, shared access to server rooms and weak power backup allow tampering, theft and outages.

5. Consolidated Risk Overview Rating Count IDs

Critical (20–25) 2 S-1, N-1

High (12–19) 12 S-2, S-3, S-4, S-5, S-6, S-7, S-8, N-2, N-3, N-4, N-5, N-6, N-7

Medium (6–11) 1 N-8

The common thread is that the two systems depend on each other: a compromise of the network (N-1, N-2) can bypass the portal's protections, and a weak portal (S-1, S-2) can expose data even on a well-run network. Controls must therefore be applied at both layers.

6. Recommended Technical Security Controls

6.1 Controls for System 1: SIS and portals S-1

Authentication

- Enforce multi-factor authentication (TOTP app or WebAuthn security keys) for all staff and administrator accounts first, then students.
- Force a password change at first login. Require at least 12 characters, check new passwords against breached-password lists, and drop forced periodic rotation.
- Store passwords with **Argon2id** (or bcrypt with cost 12 or higher), never with plain hashes such as MD5 or SHA-1.

- Apply rate limiting per account and per IP address, progressive delays after failed attempts, temporary lockout, and CAPTCHA after repeated failures.
- Issue session tokens that are random, expire after inactivity, are regenerated at login, and are sent with HttpOnly, Secure and SameSite=Lax cookie flags. **S-2 Access control and grade integrity**
- Check authorisation **on the server for every request and every record**: the loggedin student ID must match the record owner. Never trust identifiers supplied by the browser.
- Implement role-based access control (student, lecturer, exam officer, registrar, administrator) with least privilege.
- Apply a **maker-checker** rule: a lecturer enters or changes a grade, and a different authorised officer must approve it. Lock grades after publication and require a documented, approved request to change them.

S-3 Injection and input handling

- Use parameterised queries or an ORM everywhere. Example in PHP:

$stmt = $pdo->prepare('SELECT * FROM students WHERE index_no = :idx'); $stmt->execute(['idx' => $indexNo]);

- Validate input on the server by type, length and allowed characters; encode output to prevent cross-site scripting; add CSRF tokens to all state-changing forms.
- Run the database account used by the web application with minimum rights (no DROP, no schema changes, no access to other databases).

Place a web application firewall in front (for example ModSecurity with the OWASP Core Rule Set) and add a Content-Security-Policy header. **S-4 Payments and domains**

- Host every portal under the university's own domain (for example portal.upsa.edu.gh), protected with DNSSEC and registry lock, and retire look-alike domains.
- Replace manual payment entry with **API integration** to the bank or payment provider. Confirmations should arrive as server-to-server callbacks signed with HMAC-SHA256 and verified by the portal, with idempotency keys to stop duplicates.
- Reconcile payments automatically each day and alert on any mismatch.

•

S-5 Logging and segregation of duties

- Log every login, failed login, privilege change, grade change and data export, recording user, time, source IP, old value and new value.
- Ship logs in real time to a separate log server or SIEM (for example Wazuh or the ELK stack) that application administrators cannot edit. Keep logs for at least 12 months.
- Add database triggers that write grade changes to an append-only audit table; alert the registrar on bulk or out-of-hours changes.

S-6 Encryption of data in transit and at rest

- Allow only TLS 1.2 and 1.3, with HSTS and modern cipher suites. Example for nginx:

ssl_protocols TLSv1.2 TLSv1.3; ssl_prefer_server_ciphers off; add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always; add_header X-Content-Type-Options nosniff always; add_header X-Frame-Options DENY always;

- Encrypt sensitive database columns (national ID numbers, phone numbers) with **AES-256-GCM**, the same algorithm demonstrated in the accompanying encryption program, with keys held in a key management service or hardware security module and not in application code. Enable transparent data encryption for the database.
- Encrypt backups with AES-256, follow the 3-2-1 rule (three copies, two media types, one offsite), and test restores each term.

S-7 Phishing

- Publish SPF, DKIM and DMARC (policy p=reject) for upsa.edu.gh so that spoofed university e-mail is rejected.
- Display the official portal address on every student notice, run regular awareness sessions, and set up a simple channel to report suspicious pages so they can be taken down quickly. **S-8 Patching**
- Keep an inventory of every web application, framework and library. Set patch deadlines (critical within 7 days, high within 30 days) and replace end-of-life software.
- Scan regularly with an authorised scanner (OpenVAS or Nessus) and run an independent penetration test every year.

6.2 Controls for System 2: Campus network and Wi-Fi N-1

Segmentation

- Create separate VLANs and firewall zones: students, guest, staff, servers (with the SIS in its own restricted zone), network management, and CCTV or other building systems.
- Apply default-deny inter-VLAN rules on a next-generation firewall. Student networks may reach the internet and a short list of published services (portal, e-learning) and nothing else.
- Put a web application firewall and reverse proxy in a DMZ in front of the portal, with the database reachable only from the application server. **N-2 Wi-Fi security**
- Move staff and student Wi-Fi to **WPA2/WPA3-Enterprise (802.1X)** with a RADIUS server (for example FreeRADIUS). Each user authenticates individually, and traffic is encrypted with per-user keys. Use certificate-based EAP-TLS for staff devices.
- Keep guest Wi-Fi on an isolated VLAN with client isolation enabled, bandwidth limits and a captive portal served only over HTTPS.
- Enable wireless intrusion prevention to detect and contain rogue access points and evil twins, and use management-frame protection (802.11w).

N-3 Layer 2 hardening (example for Cisco-style switches)

ip dhcp snooping ip dhcp snooping

vlan 10,20 ip arp inspection vlan 10,20

interface range gi1/0/1-48 switchport

port-security switchport port-security

maximum 3 spanning-tree bpduguard

enable storm-control broadcast level

5

- Mark only uplink ports as trusted for DHCP snooping, and enable IP source guard where supported. **N-4 Management plane**
- Change every default credential and remove unused accounts. Disable Telnet, HTTP and SNMP v1/v2c. Use SSH with keys, HTTPS, and **SNMPv3** with authentication and encryption.
- Reach management interfaces only from a dedicated management VLAN through a jump host, and authenticate administrators centrally using TACACS+ or RADIUS with MFA and per-command authorisation.
- Back up device configurations automatically (for example with Oxidized or RANCID) and alert on any change. **N-5 Device control**
- Deploy network access control (for example PacketFence) to check devices at connection time, quarantine non-compliant ones and place them in a remediation VLAN.
- Require endpoint protection and automatic updates on university-owned devices, and block known malicious domains with DNS filtering.
- Apply egress filtering so that only needed outbound ports are allowed, which limits malware command-and-control traffic.

N-6 Availability

- Apply per-user and per-VLAN rate limiting and quality-of-service policies so heavy users cannot starve critical systems.
- Arrange upstream DDoS mitigation with the ISP or a scrubbing or CDN provider for public sites, and keep redundant internet links with automatic failover.

- Harden DNS: disable open recursion, enable response rate limiting and run redundant resolvers.

N-7 Monitoring and detection

- Deploy network intrusion detection and prevention (Suricata or Snort) at the internet edge and in front of the server zone.
- Collect firewall, switch, wireless controller, RADIUS, DHCP, DNS and server logs into a SIEM with correlation rules and alerting. Collect NetFlow or sFlow to spot unusual traffic.
- Define an incident response plan with roles, contact lists, severity levels and a rehearsed procedure; run a tabletop exercise at least yearly. **N-8 Physical security**
- Fit wiring closets and the server room with electronic badge locks, an access log and CCTV. Keep equipment in locked racks.
- Provide UPS and generator backup, temperature and water monitoring, and keep off-site backups.

7. Prioritised Implementation Roadmap

Phase	Actions	Addresses
0–30 days (quick wins)	Parameterised queries and server-side authorisation fixes; MFA for administrators; change default credentials; disable Telnet and SNMP v1/v2c; lockout and rate limiting on the portal; enable audit logging; publish DMARC	S-1, S-5, S-7, N-4
30–90 days	maker-checker for grades; TLS hardening and HSTS; VLAN segmentation and firewall rules; DHCP snooping and dynamic ARP inspection; encrypted backups	S-2, S-3, S-6, N-1, N-3
90–180 days	802.1X Enterprise Wi-Fi; payment API integration with signed callbacks; WAF; SIEM and IDS; NAC; move portals to the university domain; first penetration test	S-4, N-2, N-5, N-7
Ongoing	Patch management with SLAs; awareness training; annual penetration test; incident response drills; yearly risk review	S-8, N-6, N-8, all

8. Residual Risk

After the controls above are implemented and verified, the expected residual risk is Low to Medium for every item. The Critical items (S-1 and N-1) fall to Medium or Low once MFA, rate limiting and segmentation are in place. Residual risk comes mainly from human factors (phishing, password sharing), zero-day vulnerabilities and insider misuse, which is why monitoring, training and incident response remain essential. The assessment should be repeated after implementation and at least once a year.

9. Conclusion

UPSA's student systems and campus network hold sensitive data and underpin teaching, payment and examination processes. The highest-value actions are strong authentication, network segmentation and trustworthy audit logs, because they stop the most likely attacks and make the rest detectable. Most of the recommended controls use free or opensource tools, so cost is mainly staff time and training. Any follow-up technical testing must be carried out only with written authorisation from the university. **Sources**

- UPSA Student Portal Guide, Hostels and Houses (systems in use; dated 2017)
- UPSA sacks 22 students for hacking, Daily Post (February 2017 grade-tampering incident)
- Bawumia opens Free Wi-Fi for Tertiary Institutions project, Class FM (network context, UPSA among 13 beneficiaries)
- Frameworks referenced: NIST SP 800-30, NIST Cybersecurity Framework, OWASP Top 10, ISO/IEC 27001 Annex A, Ghana Data Protection Act 2012 (Act 843), Ghana Cybersecurity Act 2020 (Act 1038)